GUÍA DE ESTUDIO

Normativas, Estándares y Ciclo de Vida de la Arquitectura de Seguridad

UNIDAD	SEMANA	TIPO	NIVEL
[Unidad 1]	[Semana 2]	ESTUDIO	AVANZADO

CUGDL — Universidad de Guadalajara
Arquitectura de Sistemas de Seguridad
Licenciatura en Ciberseguridad
Autor: Carlos Pulido Rosas
[marzo 2026]

OBJETIVOS DE APRENDIZAJE

1. Distinguir el propósito y alcance de ISO 27001, NIST CSF y CIS Controls, y saber cuándo aplicar cada marco en un proyecto de arquitectura de seguridad.
2. Comparar los tres estándares en términos de enfoque, audiencia y nivel de prescripción técnica.
3. Describir las cinco fases del ciclo de vida de la arquitectura de seguridad y relacionar cada fase con las unidades del curso.

1. ¿Por qué existen los marcos de seguridad?

Antes de construir cualquier arquitectura de seguridad, una organización necesita responder tres preguntas: ¿qué proteger?, ¿cómo protegerlo? y ¿cómo demostrar que lo está haciendo bien? Los marcos de seguridad —ISO 27001, NIST CSF y CIS Controls— nacen exactamente para eso. Cada uno responde esas preguntas desde un ángulo distinto.

Piénsalos como tres capas de abstracción: ISO 27001 define el sistema de gestión (el qué y el cómo organizacional), NIST CSF ofrece un lenguaje común de riesgo (el cómo estratégico), y CIS Controls da la lista de controles técnicos concretos a implementar (el qué hacer en la práctica).

	ANALOGÍA - El arquitecto de software
	ISO 27001 es como los requisitos no funcionales del sistema: defines qué debe cumplir.
	NIST CSF es como el diseño de arquitectura: te dice cómo estructurar tu respuesta al riesgo.
	CIS Controls es como el backlog de tareas técnicas: controles específicos, priorizados, listos para ejecutar.

2. ISO 27001 - Sistema de Gestión de Seguridad de la Información

ISO 27001 es un estándar internacional publicado por la ISO. Su objetivo es establecer, implementar, mantener y mejorar continuamente un SGSI (Sistema de Gestión de Seguridad de la Información). No dicta tecnologías específicas; dicta procesos y controles organizacionales.

2.1 Estructura principal

El estándar sigue la estructura de alto nivel (HLS) común a todas las normas ISO modernas, con 10 cláusulas. Las operativas más relevantes para un arquitecto de seguridad son:

- Cláusula 4 — Contexto: entender la organización, partes interesadas y alcance del SGSI.
- Cláusula 6 — Planificación: evaluación y tratamiento de riesgos. Aquí vive el núcleo del diseño.
- Cláusula 8 — Operación: implementar los controles del Anexo A.
- Cláusula 9 — Evaluación: auditorías internas y revisión por la dirección.
- Cláusula 10 — Mejora: acciones correctivas y mejora continua (ciclo PDCA).

2.2 Anexo A — Los 93 controles

El Anexo A de ISO 27001:2022 agrupa 93 controles en 4 categorías: organizacionales (37), personas (8), físicos (14) y tecnológicos (34). Para un arquitecto, los controles tecnológicos son los más directamente aplicables: autenticación, cifrado, segmentación de red, registro de eventos y respuesta a incidentes.

Puntos clave de ISO 27001

- Es certificable, una organización puede obtener una certificación ISO 27001 auditada por terceros.
- Es orientada al riesgo, no impone controles universales; la empresa elige los relevantes según su análisis de riesgo.

- Requiere compromiso directivo — sin respaldo de la alta dirección, el SGSI no se sostiene.
- El ciclo PDCA (Plan-Do-Check-Act) es su ADN — mejora continua, no implementación única.

3. NIST CSF - Marco de Ciberseguridad del NIST

El NIST Cybersecurity Framework (CSF) fue publicado por el National Institute of Standards and Technology de EE.UU. en 2014 y actualizado a la versión 2.0 en 2024. A diferencia de ISO 27001, no es certificable ni obligatorio — es un marco de referencia voluntario diseñado para comunicar el estado de seguridad de una organización en términos de riesgo.

3.1 Las 6 funciones del CSF 2.0

NIST CSF 2.0 organiza la seguridad en seis funciones. La versión 1.1 tenía cinco; la versión 2.0 agrega GOVERN:

Función	Pregunta que responde	Ejemplo de actividad
GOVERN	¿Cómo se toman decisiones de seguridad?	Políticas, roles, gestión de riesgos corporativos
IDENTIFY	¿Qué activos tenemos y cuáles son los riesgos?	Inventario de activos, clasificación de datos
PROTECT	¿Cómo prevenimos incidentes?	Control de acceso, cifrado, hardening
DETECT	¿Cómo sabemos si algo malo ocurre?	SIEM, monitoreo de red, IDS/IPS
RESPOND	¿Qué hacemos cuando ocurre un incidente?	Plan de respuesta, comunicación
RECOVER	¿Cómo volvemos a la normalidad?	Backups, DRP, lecciones aprendidas

	ANALOGÍA - Pipeline de datos
	GOVERN es el diseño del pipeline: quién decide qué procesar y con qué reglas.
	IDENTIFY es el schema discovery: saber qué datos tienes antes de protegerlos.
	PROTECT / DETECT / RESPOND / RECOVER son las etapas: ingestar, monitorear, transformar y recuperar.

4. CIS Controls - Controles de Seguridad Críticos

Los CIS Controls (Center for Internet Security) son una lista de 18 grupos de controles técnicos y organizacionales, ordenados por impacto y dificultad de implementación. A diferencia de ISO 27001 y NIST CSF, los CIS Controls son prescriptivos: te dicen exactamente qué hacer, no solo qué lograr.

4.1 Los tres grupos de implementación (IG)

- IG1 — Higiene básica (toda organización). Inventario de hardware y software, configuraciones seguras, gestión de cuentas y privilegios. Estas defensas mínimas evitan el 85% de los ataques comunes.
- IG2 — Organizaciones con datos sensibles. Agrega gestión de vulnerabilidades, protección de email y navegador, recuperación de datos.
- IG3 — Infraestructura crítica. Todos los controles, incluyendo gestión de incidentes, pruebas de penetración y seguridad en la red.

4.2 Los 18 controles

#	Control	IG mínimo
1	Inventario de activos de hardware	IG1
2	Inventario de activos de software	IG1
3	Protección de datos	IG1
4	Configuración segura de activos	IG1
5	Gestión de cuentas	IG1
6	Gestión de control de acceso	IG1
7	Gestión continua de vulnerabilidades	IG2
8	Gestión de registros de auditoría	IG2
9	Protección de email y navegador web	IG2
10	Defensas contra malware	IG2
11	Recuperación de datos	IG2
12	Gestión de infraestructura de red	IG2
13	Monitoreo y defensa de red	IG2

14	Concienciación y entrenamiento	IG2
15	Gestión de proveedores de servicios	IG3
16	Seguridad de aplicaciones	IG3
17	Gestión de respuesta a incidentes	IG3
18	Pruebas de penetración	IG3

5. Comparativa: ¿cuándo usar cada marco?

En la práctica los tres marcos no son excluyentes. ISO 27001 da la certificación y el marco de gobierno; NIST CSF da el lenguaje de riesgo para comunicarte con la dirección; CIS Controls da el checklist técnico para el equipo de operaciones.

Criterio	ISO 27001	NIST CSF 2.0	CIS Controls v8
Origen	ISO (internacional)	NIST - EE.UU.	CIS - EE.UU.
¿Certificable?	Sí	No	No
Enfoque principal	Sistema de gestión	Gestión de riesgo	Controles técnicos
Prescripción	Media (elige controles)	Baja (principios)	Alta (qué hacer exacto)
Mejor para...	Cumplimiento y auditoría	Estrategia	Implementación técnica
Audiencia	CISO, legal, dirección	CISO, board	Equipo técnico, ops
Costo de adopción	Alto (certificación)	Bajo (gratuito)	Bajo (gratuito)

6. Ciclo de Vida de la Arquitectura de Seguridad

La arquitectura de seguridad no es un entregable único — es un proceso iterativo. El ciclo de vida describe cómo una arquitectura evoluciona desde la identificación de requisitos hasta su operación continua y mejora.

6.1 Las cinco fases

- Fase 1 — Identificación de requisitos: entender el contexto del negocio, activos críticos, amenazas relevantes y requisitos de cumplimiento. Corresponde a la cláusula 4 y 6 de ISO 27001 y a las funciones GOVERN/IDENTIFY del NIST CSF.
- Fase 2 — Diseño de arquitectura: seleccionar controles, definir segmentación de red, mecanismos de autenticación, cifrado y flujos de datos. Se aplican principios de defensa en profundidad y mínimo privilegio.

- Fase 3 — Implementación: desplegar los controles diseñados. Los CIS Controls IG1/IG2/IG3 son la guía operativa. Las prácticas DevSecOps integran la seguridad en el pipeline de desarrollo.
- Fase 4 — Verificación y validación: auditorías, pruebas de penetración, revisión de configuraciones, análisis de logs. Alimenta el ciclo PDCA de ISO 27001 y las funciones DETECT/RESPOND del NIST CSF.
- Fase 5 — Operación y mejora continua: monitoreo continuo, gestión de vulnerabilidades, respuesta a incidentes y lecciones aprendidas. El ciclo regresa a la Fase 1 con cada cambio significativo.

CASO REAL: SolarWinds - Ataque a la cadena de suministro (2020)

En 2020, atacantes comprometieron el proceso de build de SolarWinds e insertaron código malicioso en actualizaciones legítimas de su software Orion, utilizado por miles de organizaciones incluyendo agencias del gobierno de EE.UU. La intrusión pasó desapercibida durante meses.

Conexión con esta guía: el ataque explotó las fases más débiles del ciclo de vida — Fase 3 (implementación sin validación de integridad del pipeline) y Fase 4 (monitoreo insuficiente). Una organización con CIS Control 2 (inventario de software) y ISO 27001 cláusula 8.8 habría tenido mayor visibilidad. El NIST CSF identifica este escenario bajo la función DETECT.

PREGUNTAS DE REFLEXIÓN

1. Una empresa emergente de Fintech mexicana debe cumplir con la CNBV y también quiere exportar a Europa (GDPR). ¿Qué marco o combinación de marcos le recomendarías como punto de partida y por qué?
2. NIST CSF 2.0 agrega la función GOVERN que no existía en v1.1. ¿Por qué crees que se consideró necesario añadirla? ¿Qué problemas organizacionales resuelve que las otras cinco funciones no cubrían?
3. Un equipo técnico argumenta que CIS Controls es suficiente y que ISO 27001 es solo burocracia para auditorías. ¿Estás de acuerdo? ¿Qué aporta ISO 27001 de forma diferencial frente a un programa basado únicamente en CIS Controls?

RECURSOS

- [Docs] NIST Cybersecurity Framework 2.0 — https://www.nist.gov/cyberframework — gratuito
- [Docs] CIS Controls v8 — https://www.cisecurity.org/controls — gratuito (requiere registro)
- [PDF] ISO/IEC 27001:2022 — resumen público en https://www.iso.org/standard/27001
- [Video] NIST CSF 2.0 Overview — NIST YouTube @NISTgov — aprox. 20 min